

Implement Access Control Measures

DeRexi Policy Governance Assistant

Student	Kiona Wilson
Project	DeRexi
Course Area	Network Security
Date	September 9, 2026

Rubric Requirement	Implementation in This Report
1 Access Control List (ACL) configuration	Firewall ACL permitting HTTPS, restricting SSH, and applying default-deny rules.
1 access control model	Role-Based Access Control (RBAC).
1 user access level	Standard Employee access level, demonstrated with Maya in Marketing.

Report Objective

This report documents a layered access-control design for DeRexi, a policy-governance application intended for organizations in the banking and financial-services industry. The controls are designed to restrict network access, separate user privileges, and ensure that users receive only the permissions required for their responsibilities.

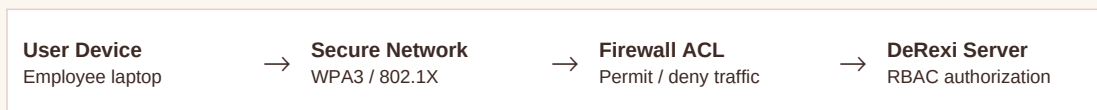
01 Access Control Strategy

DeRexi stores and processes business policies, employee-related information, policy-owner workflows, incident guidance, and administrative configuration. Access to these resources should therefore be based on both **who the user is** and **what the user's role requires**.

Security objectives

- **Least privilege:** grant only the minimum permissions needed to perform assigned work.
- **Separation of duties:** keep policy-management privileges separate from system-administration privileges.
- **Default deny:** block traffic and actions that have not been explicitly authorized.
- **Accountability:** log administrative access and denied access attempts for review.
- **Defense in depth:** combine network controls with application-level authorization.

DeRexi access path



The firewall ACL answers the network question: **Should this connection reach the resource?** RBAC then answers the application question: **What is this authenticated user allowed to do?**

02 Access Control List (ACL)

An **Access Control List (ACL)** is an ordered set of rules that permits or denies network traffic according to characteristics such as source, destination, protocol, and port. For DeRexi, the ACL is placed at the firewall protecting the application environment.

Proposed DeRexi ACL

Priority	Source	Destination	Protocol / Port	Action	Purpose
1	Authorized internal users	DeRexi application server	HTTPS / TCP 443	ALLOW	Secure application access
2	Authorized admin network	DeRexi server	SSH / TCP 22	ALLOW	Approved server administration
3	Regular employee network	DeRexi server	SSH / TCP 22	DENY	Prevent employee server administration
4	Untrusted / unauthorized traffic	DeRexi internal resources	Any	DENY	Default-deny protection

Simplified configuration example

```
ALLOW TCP from AUTHORIZED_INTERNAL_NETWORK to DEREXI_SERVER port 443
ALLOW TCP from ADMIN_NETWORK to DEREXI_SERVER port 22
DENY TCP from EMPLOYEE_NETWORK to DEREXI_SERVER port 22
DENY ALL from ANY to DEREXI_INTERNAL_NETWORK
```

Implementation example: Dana, a Policy Owner, needs HTTPS access to the DeRexi application but does not need SSH access to administer the underlying server. Lucy, the System Administrator, may use SSH only from an approved administrative network. This prevents ordinary or compromised employee accounts from reaching sensitive server-management services.

03 Access Control Model: RBAC

Role-Based Access Control (RBAC) is the selected access-control model for DeRexi. Permissions are assigned to defined roles, and users inherit the permissions of the role assigned to them. This approach is easier to manage and audit than assigning every permission individually.

DeRexi role structure

User	Role	Authorized Access
Tom	Employee / Operations	Read approved policies, ask policy questions, submit clarification requests, use Incident Assistance.
Maya	Employee / Marketing	Read approved policies, ask questions, submit feedback, use Incident Assistance.
Dana	Policy Owner / Compliance Manager	Employee functions plus management of assigned policies and review of clarification requests.
Lucy	System Administrator	Manage users and roles, authentication, security configuration, and approved system administration.

Why RBAC fits DeRexi

DeRexi already distinguishes between employees, policy owners, departments, and administrators. RBAC maps naturally to this structure and reduces the risk of **privilege creep**. For example, Dana's Policy Owner role can authorize policy-management functions without granting the system-administration permissions assigned to Lucy.

Role separation example

Maya - Standard Employee	Dana - Policy Owner	Lucy - System Administrator
Read policies Ask questions Submit feedback Incident Assistance	Employee access Manage assigned policies Review clarifications Respond to employees	Manage users Assign roles Configure security Authorized server administration

04 User Access Level

The user access level demonstrated for this report is **Standard Employee**. Maya, a Marketing employee, is used as the example. Her permissions are intentionally limited to the functions necessary to use DeRexi as an employee.

PERMITTED	RESTRICTED
Log in with an authorized employee account Search and read approved policies Ask policy-related questions Submit feedback or clarification requests Use Incident Assistance Report security-related incidents	Create administrator accounts Change another user's role Modify authentication settings Use SSH for server administration Modify system-wide security configuration Approve her own elevated privileges

How the controls work together

1. **ACL:** Determines whether Maya's device can reach the DeRexi application over an approved protocol such as HTTPS/TCP 443.
2. **Authentication:** Confirms Maya's identity when she signs in.
3. **RBAC:** Reads Maya's assigned role and determines which DeRexi functions she may use.
4. **User access level:** Limits Maya to Standard Employee capabilities and prevents administrative actions.

05 Security Benefits & Conclusion

- **Least privilege** limits unnecessary access.
- **Separation of duties** prevents policy ownership from automatically granting system administration.
- **Reduced attack surface** keeps SSH and other administrative services away from ordinary users.
- **Default-deny controls** block traffic without an approved business purpose.
- **Scalable role management** makes employee onboarding and permission reviews easier.

DeRexi's access-control implementation combines a network ACL, Role-Based Access Control, and defined user access levels. The ACL protects network paths and services; RBAC determines what authenticated users may do; and the Standard Employee access level demonstrates how an individual user's capabilities are restricted. Together, these controls provide layered protection for DeRexi while allowing employees, policy owners, and administrators to perform their authorized responsibilities.

Rubric completion: ACL configuration ✓ RBAC model ✓ Standard Employee access level ✓